TEK-UP University

Classe CII-5-J-SSIR-G — Audit selon la norme ISO/IEC 2700x — 2026-2027

Mini-rapport

Mise en place d’une architecture de prévention et de détection Anti-DDoS basée sur des outils open source

Plateforme : Red Hat Enterprise Linux — Nginx, Docker, CrowdSec, Prometheus, Grafana, OpenSCAP

Réalisé par : Rayen Sliti

Encadrant : Mourad Melliti

Date : 13 octobre 2026

Remerciements

Je remercie mon encadrant, Monsieur Mourad Melliti, pour ses conseils et son suivi tout au long de ce mini-projet, ainsi que TEK-UP University pour le cadre pédagogique et les moyens mis à disposition.

Mes remerciements vont aussi aux communautés open source (Nginx, Docker, CrowdSec, Prometheus, Grafana, OpenSCAP) dont la documentation a rendu ce travail possible.

Résumé

Ce mini-projet met en place, dans un laboratoire isolé, une architecture open source destinée à réduire l'impact des attaques par déni de service applicatives et des petits floods réseau. Une machine virtuelle Red Hat Enterprise Linux durcie héberge une application Web conteneurisée (Docker), accessible uniquement à travers un reverse proxy Nginx qui limite le débit et les connexions par adresse IP. CrowdSec analyse les journaux Nginx, détecte le comportement abusif et son bouncer applique le blocage dans nftables. Prometheus, Node Exporter et Grafana assurent la supervision ; AIDE et OpenSCAP fournissent les contrôles d'intégrité et de conformité.

Les tests réalisés montrent qu'une rafale de 100 requêtes parallèles depuis un poste client reçoit environ 22 à 23 réponses 200 et 77 à 78 réponses 429, que CrowdSec lève une alerte et décide un bannissement, et que le poste devient injoignable (délai dépassé) quelques secondes plus tard. Le scan OpenSCAP (profil CIS niveau 1 serveur) passe de 157 à 167 règles conformes et de 118 à 108 échecs. La solution ne prétend pas arrêter un DDoS volumétrique saturant le lien Internet : cette limite est assumée et discutée.

Mots-clés : Anti-DDoS, Nginx, CrowdSec, nftables, Docker, Prometheus, OpenSCAP, ISO/IEC 27001.

Table des matières

Remerciements.....2
Résumé.....3
1. Introduction et contexte.....5
2. Problématique et objectifs.....5
3. Étude des risques DDoS.....5
3.1 Catégories d'attaques DDoS.....5
3.2 Évaluation des risques du projet.....5
4. Exigences.....6
4.1 Exigences du cahier des charges.....6
4.2 Exigences fonctionnelles et de sécurité.....6
5. Architecture proposée.....6
6. Choix technologiques.....7
7. Mise en œuvre technique.....8
7.1 Durcissement SSH.....8
7.2 Pare-feu firewalld.....9
7.3 Protections noyau.....10
7.4 Application conteneurisée.....11
7.5 Nginx : reverse proxy et limitation.....11
7.6 CrowdSec et bouncer nftables.....11
7.7 Supervision.....12
7.8 Intégrité, journalisation et sudo.....13
8. Scénarios de test et résultats.....13
9. Analyse ISO/IEC 27001:2022.....15
9.2 Constats d'audit.....16
10. Conformité : scan OpenSCAP.....16
10.1 Qu'est-ce qu'OpenSCAP et pourquoi l'utiliser ?.....16
10.2 Comment lire le rapport.....16
10.3 Démarche suivie.....16
10.4 Résultats des scans.....17
11. Limites de la solution.....17
12. Recommandations d'amélioration.....18
13. Conclusion.....18
Annexes.....19
Annexe A : liste des preuves présentées dans ce rapport.....19
Annexe B : fichiers de configuration.....19
Annexe C : glossaire.....19

1. Introduction et contexte

Les attaques par déni de service distribué (DDoS) visent la disponibilité d'un service. On distingue les attaques volumétriques (saturation de la bande passante), les attaques protocolaires (épuisement des tables d'état, par exemple SYN flood) et les attaques applicatives (requêtes HTTP abusives). La norme ISO/IEC 27001 impose de protéger la disponibilité de l'information, notamment par la gestion de la capacité (A.8.6), la sécurité des réseaux (A.8.20), la journalisation (A.8.15) et la surveillance (A.8.16).

Ce travail s'inscrit dans la matière Audit selon la norme ISO 2700x. Il ne se limite pas à installer des outils : chaque risque est rattaché à une mesure, à une preuve et à un contrôle de la norme.

2. Problématique et objectifs

Comment maintenir la disponibilité d'une application Web face à des requêtes excessives ou malveillantes, tout en conservant un environnement administrable, journalisé, segmenté et aligné sur ISO/IEC 27001 ?

- Déployer une VM Red Hat Enterprise Linux durcie, utilisable comme modèle.
- Conteneuriser l'application avec Docker et Docker Compose et ne l'exposer que derrière Nginx.
- Limiter les attaques HTTP (débit, connexions, temporisations).
- Détecter les comportements anormaux à partir des journaux et bloquer automatiquement les IP malveillantes.
- Superviser la disponibilité et les ressources.
- Produire des preuves d'audit : configurations, journaux, tableaux de bord, rapports de conformité.

3. Étude des risques DDoS

3.1 Catégories d'attaques DDoS

Catégorie	Principe	Couverture par ce projet
Volumétrique	Saturation de la bande passante par un très grand nombre de paquets	Non couverte : nécessite une protection en amont (FAI, CDN, scrubbing)
Protocolaire	Épuisement des ressources réseau (SYN flood)	Partielle : SYN cookies, files d'attente agrandies, filtrage nftables
Applicative (couche 7)	Requêtes HTTP abusives, scans, bots	Principale : rate limiting Nginx, détection et blocage CrowdSec

3.2 Évaluation des risques du projet

Évaluation qualitative simplifiée, inspirée de la démarche ISO/IEC 27005 : il s'agit d'un jugement de l'auteur pour un laboratoire, non d'une mesure.

Risque	Probabilité	Impact	Niveau	Traitement
Flood HTTP sur l'application	Élevée	Élevé	Élevé	Nginx limit_req / limit_conn ; CrowdSec
Force brute sur SSH	Élevée	Élevé	Élevé	Clé SSH, root interdit, AllowUsers, 3 essais max.
Exposition directe du	Moyenne	Élevé	Élevé	Application sur 127.0.0.1 ; Nginx point

Risque	Probabilité	Impact	Niveau	Traitement
backend				d’entrée unique
SYN flood et abus réseau	Moyenne	Moyen	Moyen	SYN cookies, files agrandies, pare-feu
Modification non détectée de fichiers système	Faible	Élevé	Moyen	AIDE (contrôle quotidien)
Dérive de configuration	Moyenne	Moyen	Moyen	Sauvegardes, snapshots, OpenSCAP
DDoS volumétrique	Moyenne	Très élevé	Élevé (résiduel)	Non traité en local : protection en amont requise (risque transféré)

4. Exigences

4.1 Exigences du cahier des charges

- Hyperviseur de type 1 ou 2 avec licence valide, inscription Red Hat Developer Subscription.
- Machine virtuelle Red Hat Enterprise Linux servant de modèle.
- Conteneurisation avec Docker et Docker Compose.
- Hardening de l’hôte et administration par client SSH sécurisé.
- Trois livrables : validation technique, présentation de 5 minutes maximum, mini-rapport.

4.2 Exigences fonctionnelles et de sécurité

- Point d’entrée unique (Nginx) ; application non joignable directement.
- Authentification SSH par clé uniquement, connexion root interdite.
- Pare-feu à exposition minimale ; SELinux en mode Enforcing.
- Journalisation, supervision et contrôle d’intégrité des fichiers.
- Scan de conformité avec des preuves avant et après.

5. Architecture proposée

La passerelle « anti-ddos-gateway » est une VM Red Hat Enterprise Linux 9.8 (adresse 192.168.3.134). Le poste de test (192.168.3.1) joue à la fois le rôle de client légitime, d’administrateur (SSH) et de source de rafale.

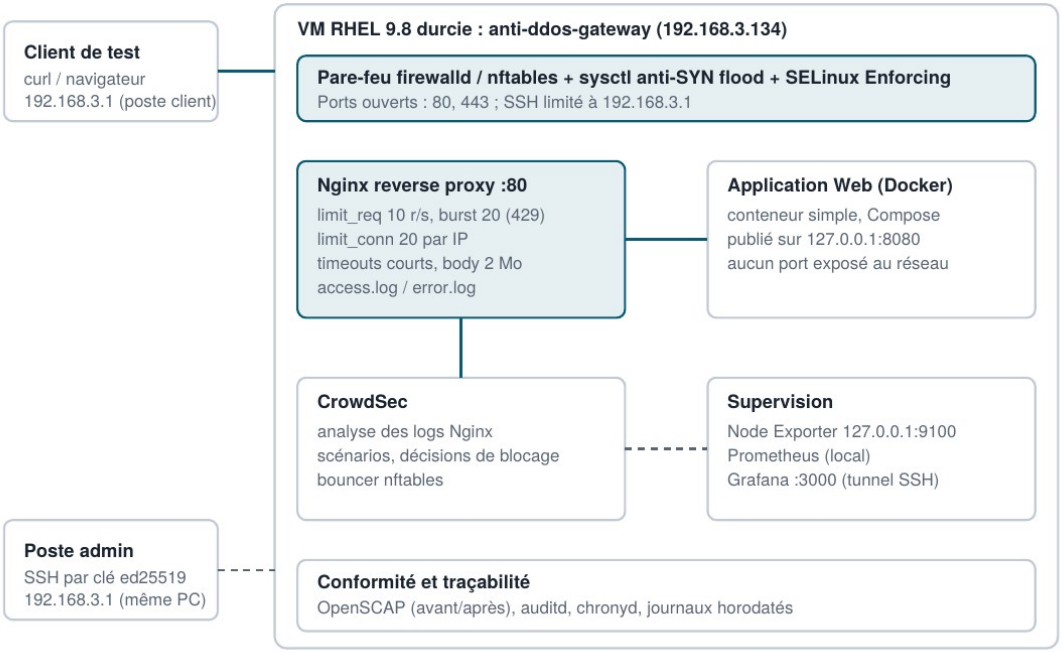


Figure 1 : Schéma d'architecture de la passerelle anti-ddos-gateway

Élément	Réseau / port	Règle
Administration SSH	TCP 22	Clé SSH ; accepté seulement depuis 192.168.3.1 (règle riche firewalld)
Nginx	TCP 80/443	Seul service Web accessible ; limite de débit et de connexions
Application Web (Docker)	127.0.0.1:8080	Jamais publiée hors de l'hôte
CrowdSec (API locale)	127.0.0.1:8081	Non exposée
Node Exporter / Prometheus	127.0.0.1:9100 / 9090	Non exposés
Grafana	127.0.0.1:3000	Accès par tunnel SSH uniquement

Flux principal : client → pare-feu → Nginx (limites) → application. CrowdSec lit les journaux Nginx ; sa décision est appliquée par le bouncer dans une table nftables dont la chaîne a une priorité supérieure à celle de firewalld, de sorte que les paquets d'une IP bannie sont rejetés avant d'atteindre Nginx.

6. Choix technologiques

Besoin	Outil	Justification
Système hôte	Red Hat Enterprise Linux 9.8	SELinux, OpenSCAP, paquets supportés
Conteneurs	Docker 29.8.2, Compose 5.6.0	Exigés par le cahier des charges (Podman reste l'alternative native de RHEL)
Reverse proxy	Nginx	Rate limiting, limitation de connexions, journaux détaillés
Détection / blocage	CrowdSec 1.8.1 + bouncer nftables	Scénarios communautaires, décisions automatiques, application au pare-feu

Besoin	Outil	Justification
Pare-feu	firewalld (backend nftables)	Politique restrictive, règles riches
Supervision	Prometheus, Node Exporter, Grafana	Métriques de l'hôte et de CrowdSec, tableau de bord
Intégrité	AIDE 0.19.2	Détection des modifications de fichiers
Conformité	OpenSCAP + SCAP Security Guide	Rapports de conformité (profil CIS niveau 1 serveur)

7. Mise en œuvre technique

La VM de travail est un clone de la machine préparée pour la certification RHCSA/RHCE. Chaque étape a été précédée d'un snapshot et suivie d'une vérification.

7.1 Durcissement SSH

Un fichier dédié /etc/ssh/sshd_config.d/00-hardening.conf est lu avant les fichiers par défaut. Une clé ed25519 générée sur le poste d'administration remplace le mot de passe.

Paramètre (sshd -T)	Avant	Après
permitrootlogin	yes	no
passwordauthentication	yes	no
maxauthtries	6	3
x11forwarding	yes	no
allowusers	(absent)	rayen

Une contradiction a été corrigée : le fichier 01-permitrootlogin.conf contenait encore PermitRootLogin yes ; la ligne a été commentée après sauvegarde. Une bannière d'avertissement (/etc/issue.net) est affichée avant l'authentification.

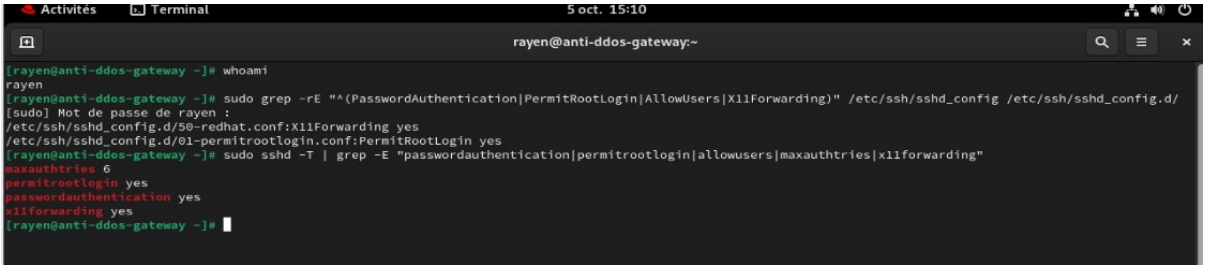


Figure 2 : Configuration SSH avant durcissement : permitrootlogin yes, passwordauthentication yes, maxauthtries 6, x11forwarding yes



Figure 3 : Configuration SSH effective après durcissement (sshd -T)

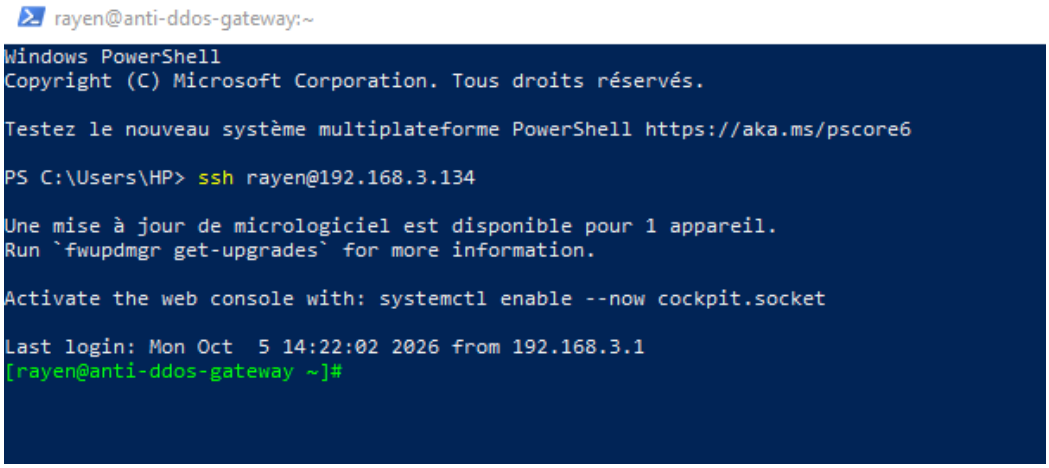


Figure 4 : Connexion SSH par clé depuis le poste d'administration, sans mot de passe

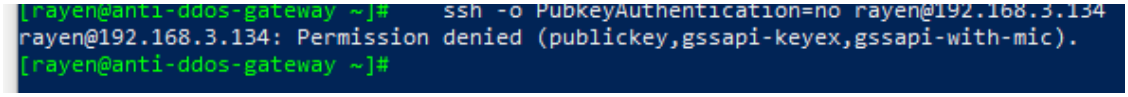


Figure 5 : Test sans clé : « Permission denied (publickey,…) », le mot de passe n'est plus accepté

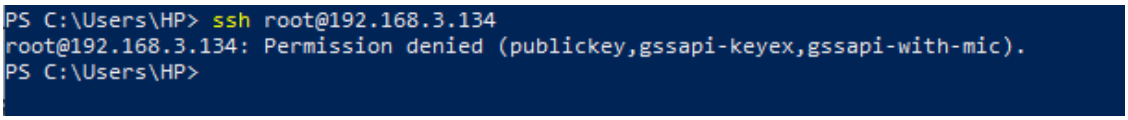


Figure 6 : Connexion en root refusée depuis le poste client

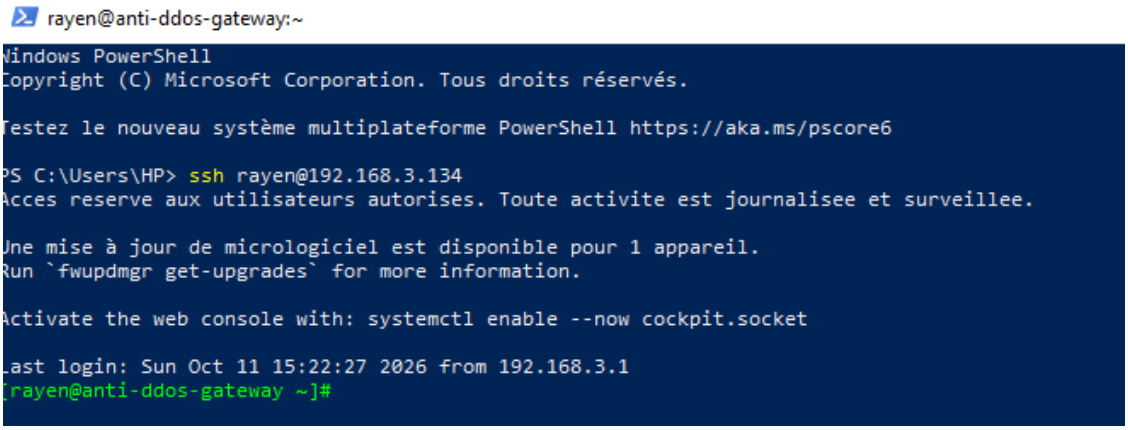


Figure 7 : Bannière d'avertissement affichée avant l'authentification

7.2 Pare-feu firewalld

État	Services ouverts
Avant	cockpit, dhcpv6-client, ssh (pour tous)
Après	http, https ; ssh seulement depuis 192.168.3.1 (règle riche)

Les règles ont d'abord été appliquées en mode temporaire, testées avec une seconde session SSH, puis rendues permanentes.

```
rayen@anti-ddos-gateway ~]# sudo firewall-cmd --state
running
rayen@anti-ddos-gateway ~]# sudo firewall-cmd --get-active-zones
public
  interfaces: ens160
rayen@anti-ddos-gateway ~]# sudo firewall-cmd --list-all
public (active)
  target: default
  icmp-block-inversion: no
  interfaces: ens160
  sources:
  services: cockpit dhcpv6-client ssh
  ports:
  protocols:
  forward: yes
  masquerade: no
  forward-ports:
  source-ports:
  icmp-blocks:
  rich rules:
rayen@anti-ddos-gateway ~]#
```

Figure 8 : Pare-feu avant modification : services cockpit, dhcpv6-client, ssh

```
[rayen@anti-ddos-gateway ~]# sudo firewall-cmd --add-service=http
sudo firewall-cmd --add-service=https
sudo firewall-cmd --add-rich-rule='rule family="ipv4" source address="192.168.3.1" service name="ssh" accept'
sudo firewall-cmd --remove-service=ssh
sudo firewall-cmd --remove-service=cockpit
sudo firewall-cmd --remove-service=dhcpv6-client
success
success
success
success
success
success
[rayen@anti-ddos-gateway ~]#
```

Figure 9 : Application des règles en mode temporaire (http, https, règle riche SSH, retrait de ssh, cockpit, dhcpv6-client)

```
public (active)
  interfaces: ens160
  services: http https
  rich rules:
        rule family="ipv4" source address="192.168.3.1" service name="ssh" accept
```

Figure 10 : Pare-feu après rendu permanent (firewall-cmd --list-all)

```
PS C:\Users\HP> ssh rayen@192.168.3.134

Une mise à jour de micrologiciel est disponible pour 1 appareil.
Run `fwupdmgr get-upgrades` for more information.

Activate the web console with: systemctl enable --now cockpit.socket

Last login: Mon Oct  5 15:14:54 2026 from 192.168.3.1
[rayen@anti-ddos-gateway ~]#
```

Figure 11 : Nouvelle connexion SSH acceptée depuis 192.168.3.1 après modification

7.3 Protections noyau

Le fichier /etc/sysctl.d/99-anti-ddos.conf fixe notamment tcp_syncookies = 1, tcp_max_syn_backlog = 4096, somaxconn = 1024, tcp_synack_retries = 2 et rp_filter = 1, pour renforcer l'hôte contre les SYN floods et l'usurpation d'adresses.

```
net.ipv4.tcp_syncookies = 1
net.ipv4.tcp_max_syn_backlog = 4096
net.core.somaxconn = 1024
net.ipv4.tcp_synack_retries = 2
net.ipv4.conf.all.rp_filter = 1
```

Figure 12 : Valeurs sysctl actives (sysctl --system appliqué)

7.4 Application conteneurisée

L'application (image nginx:alpine, page statique en lecture seule, option no-new-privileges) est déployée par Docker Compose et publiée uniquement sur 127.0.0.1:8080. Docker contournant firewalld pour les ports publiés, cette restriction à l'adresse locale est la mesure qui garantit l'isolation. Le test depuis le poste client (curl sur le port 8080) se termine par un dépassement de délai, tandis que la page est servie via Nginx sur le port 80.

```
$ sudo ss -tlnp | grep 8080
LISTEN 0 1024 127.0.0.1:8080 0.0.0.0:* users:(("docker-proxy",pid=106521,fd=8))
$ curl -s http://127.0.0.1:8080 | head -5
<!DOCTYPE html> ... <h1>Application de test - Projet Anti-DDoS</h1>
```

Figure 13 : Le backend n'écoute que sur 127.0.0.1:8080

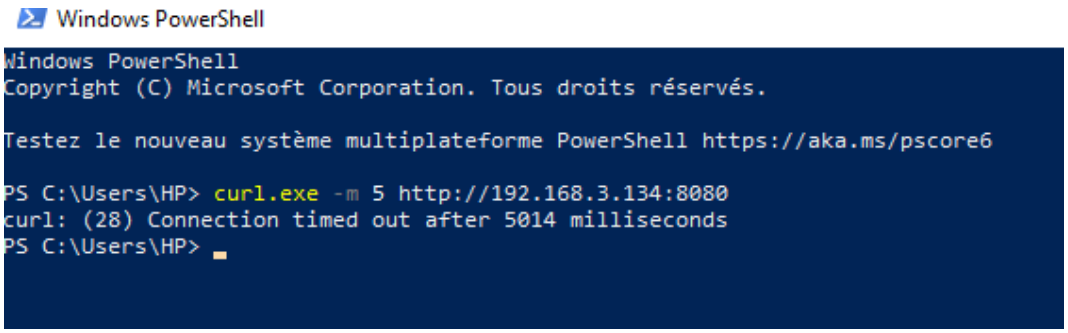


Figure 14 : Depuis le poste client : curl sur le port 8080, délai dépassé (backend injoignable)

7.5 Nginx : reverse proxy et limitation

Le fichier /etc/nginx/conf.d/anti-ddos.conf définit une limite de 10 requêtes par seconde et par IP avec une tolérance de 20 requêtes (burst), 20 connexions simultanées par IP, des délais courts (10 à 15 secondes), un corps de requête limité à 2 Mo et le code 429 pour les refus. Un point de contrôle /health répond sans solliciter l'application. Le bloc serveur par défaut de nginx.conf a été commenté afin de supprimer l'ambiguïté sur le port 80 ; SELinux reste actif et le booléen httpd_can_network_connect autorise uniquement la connexion au backend.

7.6 CrowdSec et bouncer nftables

CrowdSec était présent sans configuration d'acquisition. Les sources de journaux (anti-ddos-access.log et anti-ddos-error.log) ont été déclarées, l'API locale déplacée sur le port 8081 (le port 8080 est utilisé par l'application), et les collections nginx, base-http-scenarios et http-cve installées. Le diagnostic avec cscli explain a montré que les lignes n'étaient pas analysées tant que le parseur dateparse-enrich n'était pas activé ; après correction, le parseur nginx-logs réussit et le scénario nginx-req-limit-exceeded est alimenté.

Pour le laboratoire, la durée de bannissement a été réduite de 4 heures à 2 minutes (profiles.yaml, sauvegardé avant modification). Le bouncer crowdsec-firewall-bouncer en mode nftables est actif et interroge l'API locale ; il crée les tables « ip crowdsec » et « ip6 crowdsec6 ».

```
line: 192.168.3.1 - - [06/Oct/2026:11:22:29 +0100] "GET /?96 HTTP/1.1" 429 169 "-" "curl/8.13.0"
  s00-raw    : [KO] syslog-logs  /  [OK] non-syslog
  s01-parse  : [OK] crowdsecurity/nginx-logs
  s02-enrich : [OK] dateparse-enrich, [OK] http-logs
  parser success ; scénario alimenté : crowdsecurity/http-crawl-non_statics
```

Figure 15 : cscli explain : la ligne de journal est désormais analysée

```
[rayen@anti-ddos-gateway webapp]# sudo cscli alerts list
[sudo] Mot de passe de rayen :
```

ID	value	reason	country	as	decisions	created_at	kind
7	Ip:192.168.3.1	crowdsecurity/nginx-req-limit-exceeded			ban:1	2026-10-10T14:23:49Z	crowdsec
6	Ip:192.168.3.1	crowdsecurity/nginx-req-limit-exceeded			ban:1	2026-10-10T13:14:36Z	crowdsec
4	Ip:192.168.3.1	crowdsecurity/nginx-req-limit-exceeded			ban:1	2026-10-06T14:17:51Z	crowdsec
2	Ip:192.168.3.1	crowdsecurity/nginx-req-limit-exceeded			ban:1	2026-10-06T12:13:51Z	crowdsec

```
[rayen@anti-ddos-gateway webapp]# sudo cscli decisions list
```

ID	Source	Scope:Value	Reason	Action	Country	AS	Events	expiration	Alert ID
45004	crowdsec	Ip:192.168.3.1	crowdsecurity/nginx-req-limit-exceeded	ban			6	43s	7

```
[rayen@anti-ddos-gateway webapp]#
```

Figure 16 : Alerte nginx-req-limit-exceeded sur 192.168.3.1 et décision « ban » (cscli alerts list / decisions list)

```
cs-firewall-bouncer-1791637308  127.0.0.1  Valid  Last API pull 2026-10-10T13:11:32Z  crowdsec-firewall-bouncer v0.0.36
table ip crowdsec
table ip6 crowdsec6
```

Figure 17 : Bouncer nftables connecté à l'API (cscli bouncers list ; nft list tables)

7.7 Supervision

Node Exporter, Prometheus et Grafana tournent en conteneurs avec le réseau de l'hôte et n'écoutent que sur 127.0.0.1 (vérifié avec ss). Grafana est consulté depuis le poste d'administration par un tunnel SSH, ce qui évite d'ouvrir un port. Le tableau de bord « Node Exporter Full » est importé. La mémoire de la VM a dû être portée de 2 à 4 Go : à 2 Go, le swap était utilisé et la VM ralentissait.

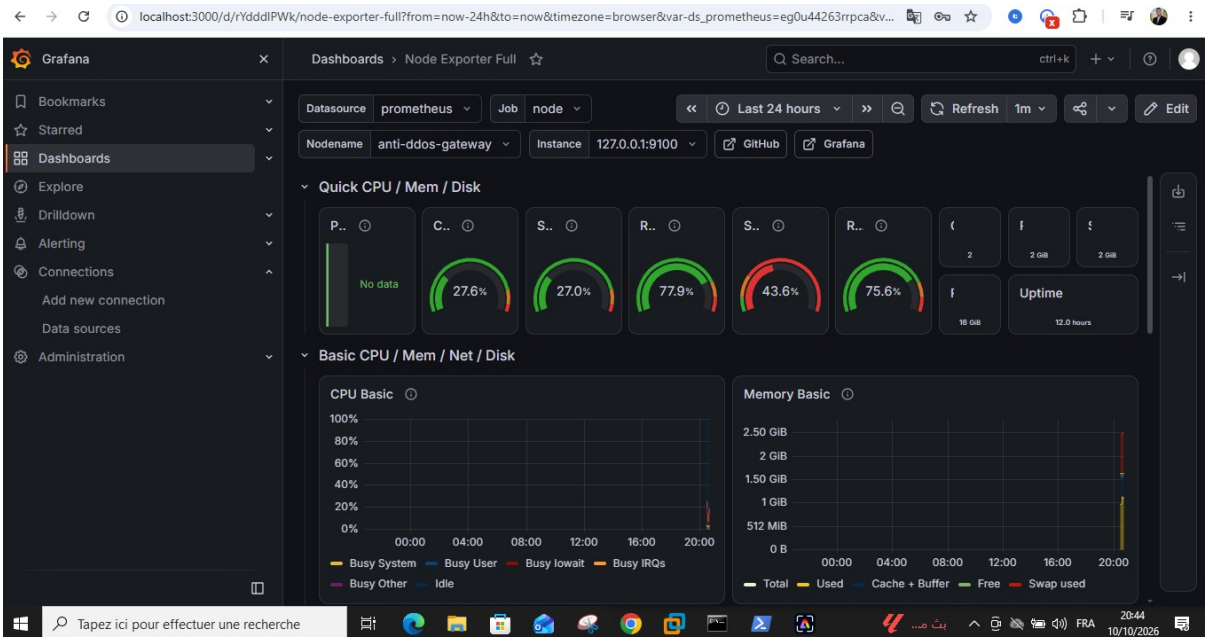


Figure 18 : Tableau de bord Grafana « Node Exporter Full » alimenté par Prometheus

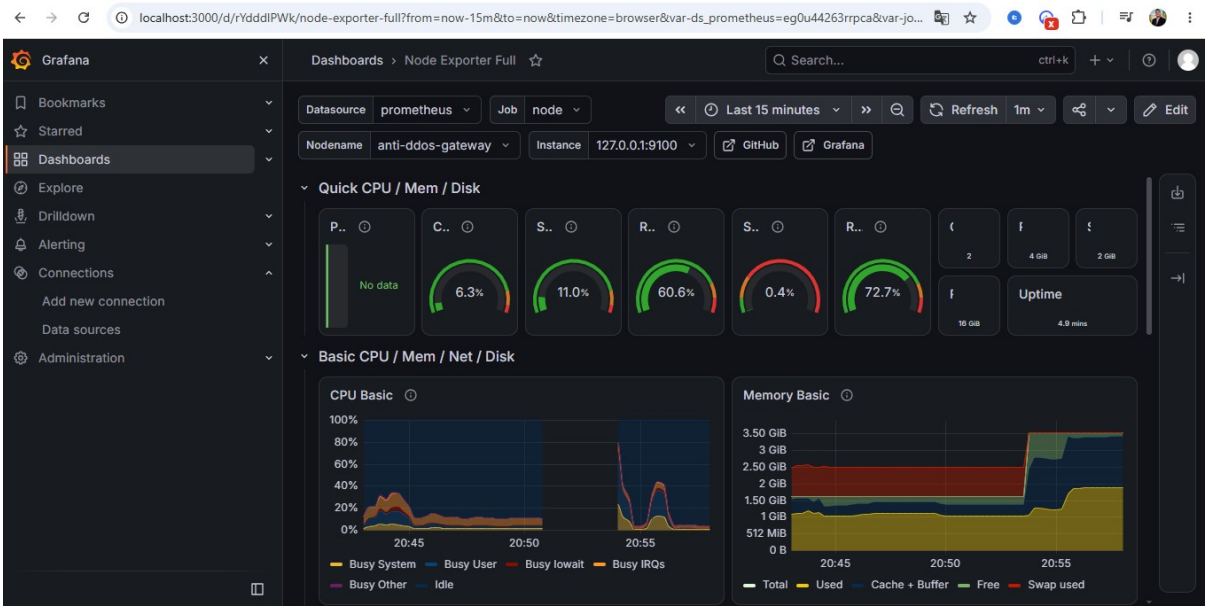


Figure 19 : Grafana après passage à 4 Go de RAM et redémarrage de la VM (swap à 0,4 %)

```
rayen@anti-ddos-gateway monitoring]# free -h
               total        used        free      shared  buff/cache   available
Mem:           3,5Gi       2,1Gi       179Mi        14Mi       1,5Gi       1,4Gi
Swap:          2,0Gi       7,0Mi       2,0Gi
rayen@anti-ddos-gateway monitoring]# sudo systemctl is-active firewalld auditd chronyd nginx docker crowdsec crowdsec-firewall-bouncer
[sudo] Mot de passe de rayen :
active
active
active
active
active
active
active
rayen@anti-ddos-gateway monitoring]# sudo docker ps --format "table {{.Names}}\t{{.Status}}"
NAMES                     STATUS
monitoring-prometheus-1   Up 3 minutes
monitoring-grafana-1      Up 3 minutes
monitoring-node-exporter-1   Up 3 minutes
webapp                    Up 3 minutes
rayen@anti-ddos-gateway monitoring]# curl -s -o /dev/null -w "%{http_code}\n" http://127.0.0.1/health
200
rayen@anti-ddos-gateway monitoring]#
```

Figure 20 : Après redémarrage : sept services actifs, quatre conteneurs démarrés, /health = 200

7.8 Intégrité, journalisation et sudo

AIDE a construit une base de référence de 191 856 entrées en 7 min 57 s, avec exclusion de /var/lib/docker (fichiers instables) et surveillance renforcée des outils d'audit ; un contrôle quotidien est planifié (cron). Le premier contrôle a signalé exactement deux changements, ceux effectués après la création de la base (fichier /etc/cron.d/aide-check ajouté et répertoire /etc/cron.d modifié), ce qui illustre la détection de modification. Sudo utilise un pseudo-terminal (use_pty) et un journal dédié /var/log/sudo.log ; le fichier a été validé par visudo avant installation.

```
AIDE successfully initialized database. Number of entries: 191856
Start 2026-10-11 15:32:07 ; End 15:40:04 (run time: 7m 57s)
aide --check : Added entries: 1 (/etc/cron.d/aide-check) ; Changed entries: 1 (/etc/cron.d)
sudo : visudo -c -> /etc/sudoers.d/00-hardening : analyse réussie ; /var/log/sudo.log enregistre les commandes
```

Figure 21 : AIDE (base de référence et premier contrôle) et journal sudo

8. Scénarios de test et résultats

Tous les tests sont réalisés dans le laboratoire isolé, sur des machines personnelles. La « rafale » est une série de 100 requêtes HTTP envoyées 20 par 20 en parallèle depuis le poste client.

Scénario	Résultat mesuré	Preuve
Requête nominale sur /health	HTTP 200 (« OK »)	Capture terminal

Scénario	Résultat mesuré	Preuve
Rafale de 100 requêtes depuis le poste client	22 réponses 200 et 78 réponses 429 (autres mesures : 23/77 ; en local depuis la VM : 89/11)	Capture PowerShell, access.log et error.log
Isolation du backend	Port 8080 injoignable depuis le poste client ; écoute sur 127.0.0.1	Capture curl et ss -tlnp
Détection CrowdSec	Alerte nginx-req-limit-exceeded sur 192.168.3.1, décision « ban » liée	cscli alerts list / decisions list
Blocage effectif	Après la rafale : 200 à 17:09:17, puis dépassement de délai à chaque test à partir de 17:09:22	Capture PowerShell (boucle de tests toutes les 5 s)
Compteur de paquets rejetés	Compteur de la liste noire nftables : 57 paquets rejetés lors des essais précédents	nft list table ip crowdsec
Redémarrage de la VM	Sept services actifs, quatre conteneurs démarrés, /health = 200	systemctl is-active, docker ps

Le blocage commence quelques secondes après la rafale : CrowdSec doit lire les lignes de journal et lever l'alerte, puis le bouncer lit la décision à intervalle régulier. Les valeurs exactes dépendent de la machine ; seules les mesures ci-dessus ont été relevées.

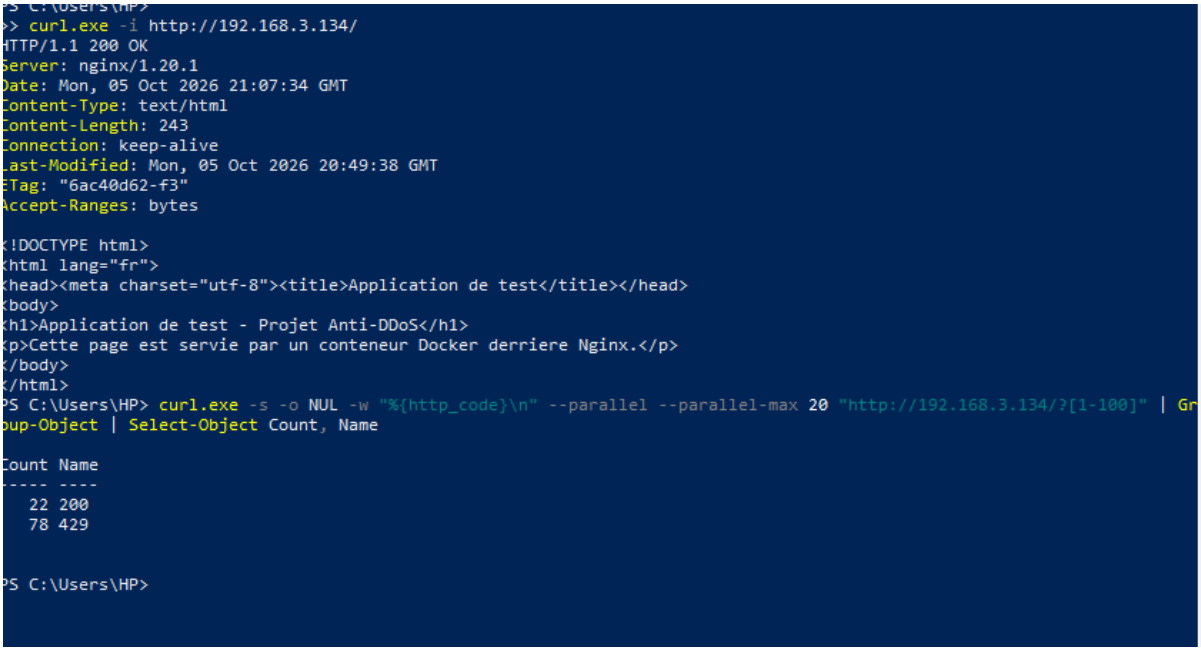


Figure 22 : Rafale de 100 requêtes depuis le poste client : 22 réponses 200 et 78 réponses 429

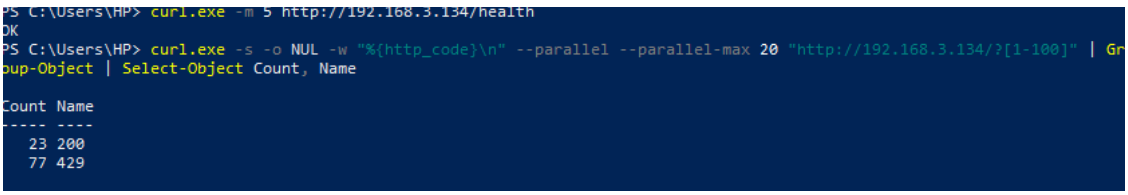


Figure 23 : Seconde mesure : 23 réponses 200 et 77 réponses 429

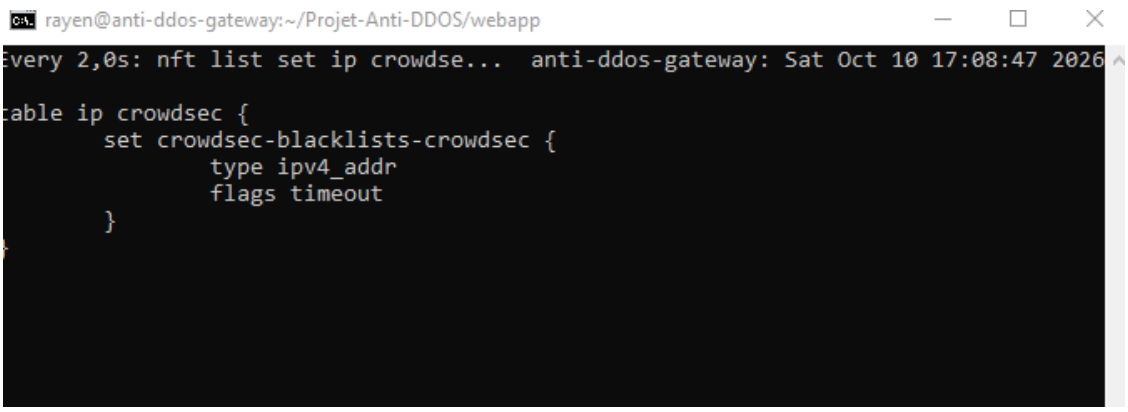


Figure 24 : Table nftables de la liste noire CrowdSec avant la rafale (ensemble vide)

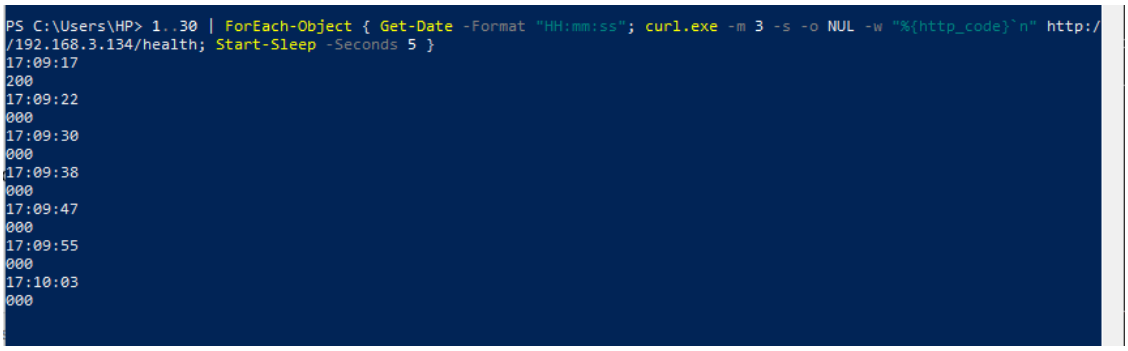


Figure 25 : Boucle de tests toutes les 5 s : 200 à 17:09:17, puis 000 (délai dépassé) à partir de 17:09:22

```
chain crowdsec-chain-input { type filter hook input priority filter - 10; policy accept;
    ip saddr @crowdsec-blacklists-crowdsec counter name "crowdsec-blacklists-crowdsec" drop
counter crowdsec-blacklists-crowdsec { packets 57 bytes 11200 }
```

Figure 26 : Chaîne nftables du bouncer (priorité avant firewalld) et compteur de paquets rejetés

9. Analyse ISO/IEC 27001:2022

Risque	Mesure mise en œuvre	Preuve d'audit	Contrôle
Indisponibilité par flood HTTP	limit_req, limit_conn, délais courts	Configuration Nginx, codes 429	A.8.6
Abus réseau, exposition inutile	firewalld, sysctl, application sur 127.0.0.1	list-all, sysctl, ss	A.8.20, A.8.22
Accès non autorisé à l'hôte	SSH par clé, root interdit, AllowUsers, SELinux	sshd -T avant/après	A.8.5
Détection tardive d'un incident	CrowdSec, Prometheus, Grafana, AIDE	Alertes, décisions, tableau de bord	A.8.16
Manque de traçabilité	Journaux Nginx, sudo.log, auditd	Extraits horodatés	A.8.15
Dérive de configuration	Sauvegardes avant modification, AIDE, snapshots	Fichiers .bak, base AIDE	A.8.9
Vulnérabilités non corrigées	Mises à jour, OpenSCAP	Historique dnf, rapports	A.8.8
Utilisation inappropriée	Bannière d'avertissement	Capture de la connexion	A.5.10
Interruption de service	Redémarrage testé, snapshots, bannissement temporaire réversible	Test de redémarrage	A.5.30

9.2 Constats d’audit

Au fil du projet, plusieurs écarts ont été relevés, corrigés ou classés. Cette liste est présentée comme le ferait un rapport d’audit.

N°	Constat	Preuve	Suite donnée
C1	SSH autorisait root et les mots de passe	sshd -T avant durcissement	Corrigé (00-hardening.conf)
C2	Un fichier 01-permitrootlogin.conf contredisait le durcissement	Relevé grâce au scan OpenSCAP intermédiaire	Corrigé après sauvegarde ; contrôler avec sshd -T
C3	Le pare-feu laissait cockpit, dhcpv6 et ssh ouverts à tous	firewall-cmd --list-all avant	Corrigé (http, https, ssh restreint)
C4	CrowdSec lisait des journaux sans les analyser (0 ligne analysée)	cscli metrics, cscli explain	Corrigé (parseur dateparse-enrich)
C5	VM sous-dimensionnée (2 Go, swap utilisé)	Grafana, free -h	Corrigé (4 Go)
C6	118 règles CIS en échec au premier scan	Rapport OpenSCAP initial	10 corrigées ; 108 restantes classées
C7	DDoS volumétrique non couvert localement	Analyse de risques	Risque résiduel accepté ; protection en amont recommandée

10. Conformité : scan OpenSCAP

10.1 Qu’est-ce qu’OpenSCAP et pourquoi l’utiliser ?

SCAP (Security Content Automation Protocol) est un ensemble de standards qui décrit des règles de sécurité sous une forme lisible par une machine. OpenSCAP est l’outil open source qui lit ces règles et les compare à la configuration réelle d’un système. SCAP Security Guide fournit les règles pour Red Hat Enterprise Linux. Un profil regroupe les règles d’un référentiel : ici le CIS (Center for Internet Security), niveau 1, pour un serveur.

Dans un audit, affirmer « mon serveur est durci » ne suffit pas : il faut une preuve objective et reproductible. OpenSCAP vérifie plusieurs centaines de points sans intervention humaine, produit un rapport daté et permet de comparer un état avant et après. Il apporte ainsi des preuves pour A.8.9 (gestion de configuration) et A.8.8 (gestion des vulnérabilités techniques).

10.2 Comment lire le rapport

- Chaque règle a un résultat : pass (conforme), fail (non conforme) ou notapplicable (ne concerne pas ce système).
- Le score est la part de règles réussies, pondérée par la gravité (high, medium, low).
- Chaque règle détaille sa description, sa justification et, souvent, la commande de correction.
- Un échec n’est pas forcément une faute : il peut être accepté et justifié (par exemple parce qu’il est nécessaire à l’architecture).

10.3 Démarche suivie

- Scan avec le profil CIS niveau 1 serveur, sans remédiation automatique, pour ne pas risquer de couper SSH ou les services.
- Analyse des échecs et classement en trois groupes : à corriger, à accepter, à reporter.
- Correction manuelle des règles sûres (bannières, sudo, AIDE, ligne PermitRootLogin), avec sauvegarde avant chaque changement.

- Second scan pour mesurer l'évolution.

10.4 Résultats des scans

Le profil retenu est « CIS Red Hat Enterprise Linux 9 Benchmark for Level 1 – Server ». Le premier scan a été réalisé après le durcissement de SSH, du pare-feu et du noyau ; il représente donc l'état initial de cette étape et non celui d'une machine non configurée. Les corrections de la phase suivante (bannière, sudo, AIDE, ligne PermitRootLogin) sont comptées dans le second scan. Aucune remédiation automatique n'a été utilisée, pour ne pas risquer de couper l'accès SSH ou les services.

Résultat	Scan initial	Scan final	Évolution
Règles conformes (pass)	157	167	+10
Règles en échec (fail)	118	108	−10
Non applicables	20	20	0
Score OpenSCAP (pondéré par la gravité)	61,27 %	non relevé	—
Ratio pass / (pass + fail), 275 règles	57,1 %	60,7 %	+3,6 points

Les règles AIDE (4), bannières et sudo font partie des corrections. Les échecs restants sont regroupés ci-dessous, avec la décision prise. Le score pondéré d'OpenSCAP n'a été relevé que pour le scan initial (61,27 %) ; pour le scan final, le ratio de règles conformes (60,7 %) est indiqué ci-dessus.

Écarts restants	Décision et justification
Règles GNOME3 (écran de veille, automount, XDMCP, bannière graphique)	Accepté : VM issue d'une certification avec bureau ; absent d'une installation minimale
/tmp sur une partition séparée	Accepté : impossible sur une VM déjà installée
Paquet nginx installé ; IPv4 forwarding ; service nftables	Accepté : nécessaires à l'architecture (reverse proxy, réseau Docker, bouncer)
pam_faillock, politique de mots de passe PAM, durée de vie des mots de passe	Reporté : risque de blocage de sudo ; accès SSH par clé uniquement
Services et modules noyau inutiles (Bluetooth, CUPS, Avahi, cramfs, usb-storage…)	À traiter sur une installation minimale ; amélioration future
Paramètres sysctl IPv6, journald, umask, permissions cron, paramètres SSH complémentaires	À traiter : améliorations futures à faible risque

```
Profil : CIS Red Hat Enterprise Linux 9 Level 1 - Server (cis_server_l1), contenu SSG 0.1.82
Scan initial (10/10/2026) : 157 pass / 118 fail / 20 notapplicable ; score OpenSCAP 61,27 %
  gravité des échecs : 4 high, 97 medium, 11 low, 6 autres
Scan final (11/10/2026)   : 167 pass / 108 fail / 20 notapplicable ; score pondéré non relevé (ratio
pass / (pass + fail) : 60,7 %)
```

Figure 27 : Résumé des deux scans OpenSCAP

11. Limites de la solution

- Une VM locale ne peut pas absorber un DDoS volumétrique : si le lien Internet est saturé, le filtrage local est inefficace car le trafic a déjà consommé la bande passante. Une protection en amont (fournisseur d'accès, CDN/WAF, scrubbing) est indispensable en production.

- Les tests sont des rafales contrôlées provenant d’une seule adresse ; une attaque distribuée réelle viendrait de nombreuses sources.
- Le système est Red Hat Enterprise Linux 9.8, alors que le sujet évoque la version 10 la plus récente ; les commandes sont équivalentes et la démarche est reproductible.
- Les adresses privées sont normalement ignorées par CrowdSec en production ; la durée de bannissement (2 minutes) est une adaptation de laboratoire.
- Le scan final compte 167 règles conformes sur 275 (60,7 %) : une partie des écarts est acceptée et justifiée, une autre reste à traiter.
- Les images de supervision utilisent la balise « latest » en laboratoire ; en production, des versions fixées sont nécessaires.

12. Recommandations d’amélioration

- Ajouter une protection en amont (CDN/WAF ou service anti-DDoS du fournisseur) et configurer la récupération de l’adresse réelle du client (real_ip).
- Régler les seuils de limitation sur le trafic réel pour éviter de bloquer des utilisateurs derrière un même NAT.
- Mettre en place HTTPS (certificat TLS), puis un WAF applicatif (ModSecurity avec OWASP CRS ou AppSec de CrowdSec).
- Traiter les écarts OpenSCAP restants (pam_faillock, mots de passe, journald, services inutiles) sur une installation minimale.
- Centraliser les journaux, définir des alertes (Prometheus Alertmanager) et rédiger une procédure de réponse à incident testée.
- Prévoir de la haute disponibilité (second nœud, répartiteur de charge) et des sauvegardes.

13. Conclusion

L’architecture réalisée répond à l’objectif du projet : réduire l’impact des abus applicatifs, détecter un comportement anormal, bloquer automatiquement la source et garder des preuves exploitables en audit. Chaque mesure est rattachée à un risque et à un contrôle ISO/IEC 27001:2022, et les résultats présentés sont des mesures réelles. Le projet montre aussi ses limites : sans protection en amont, aucune VM ne résiste à une saturation volumétrique. La démarche reste réutilisable et pourrait être rejouée sur une installation minimale de Red Hat Enterprise Linux 10.

Annexes

Annexe A : liste des preuves présentées dans ce rapport

- Configuration SSH avant et après (sshd -T) ; refus de la connexion par mot de passe et de root
- Pare-feu avant et après (firewall-cmd --list-all)
- Valeurs sysctl
- Application Docker : compose.yaml, docker compose ps, ss -tlnp, timeout depuis le poste client
- Nginx : configuration, rafale (200/429), extraits d'access.log et error.log
- CrowdSec : cscli explain, alertes, décisions, collections, bouncer
- Mesure du blocage : boucle PowerShell (200 puis 000)
- Grafana : tableau de bord ; sortie de ss pour les ports 9090, 9100, 3000
- AIDE : initialisation (191 856 entrées) et premier contrôle
- Sudo : visudo et /var/log/sudo.log ; bannière SSH
- Rapports OpenSCAP avant et après (HTML)

Annexe B : fichiers de configuration

- /etc/ssh/sshd_config.d/00-hardening.conf
- /etc/sysctl.d/99-anti-ddos.conf
- /etc/nginx/conf.d/anti-ddos.conf
- /etc/crowdsec/acquis.d/nginx.yaml et /etc/crowdsec/profiles.yaml
- ~/Projet-Anti-DDOS/webapp/compose.yaml et ~/Projet-Anti-DDOS/monitoring/compose.yaml
- /etc/sudoers.d/00-hardening et /etc/aide.conf (lignes ajoutées)

Ne pas inclure la clé API du bouncer ni le mot de passe de Grafana dans les annexes.

Annexe C : glossaire

Terme	Définition
DDoS	Attaque par déni de service distribué visant la disponibilité d'un service
Rate limiting	Limitation du nombre de requêtes acceptées par adresse IP et par seconde
Burst	Tolérance d'un pic de requêtes avant de commencer à rejeter
429	Code HTTP « Too Many Requests » : trop de requêtes
Reverse proxy	Serveur placé devant l'application, par lequel passe tout le trafic
Bouncer	Composant qui applique les décisions de CrowdSec (ici dans nftables)
nftables	Moteur de filtrage de paquets du noyau Linux
SELinux	Contrôle d'accès obligatoire de RHEL, ici en mode Enforcing
AIDE	Outil qui détecte la modification de fichiers par comparaison d'empreintes
OpenSCAP / CIS	Outil de scan de conformité / référentiel de bonnes pratiques de sécurité